



Computer Systems Security

Dr. Sandra Wahid

A Definition of Computer Security

The **protection** afforded to an **automated** information system in order to attain the applicable objectives of preserving the **integrity**, **availability**, and **confidentiality** of information system resources (includes hardware, software, firmware, information/data, and telecommunications).

CIA Triad

- The three concepts embody the fundamental security objectives.

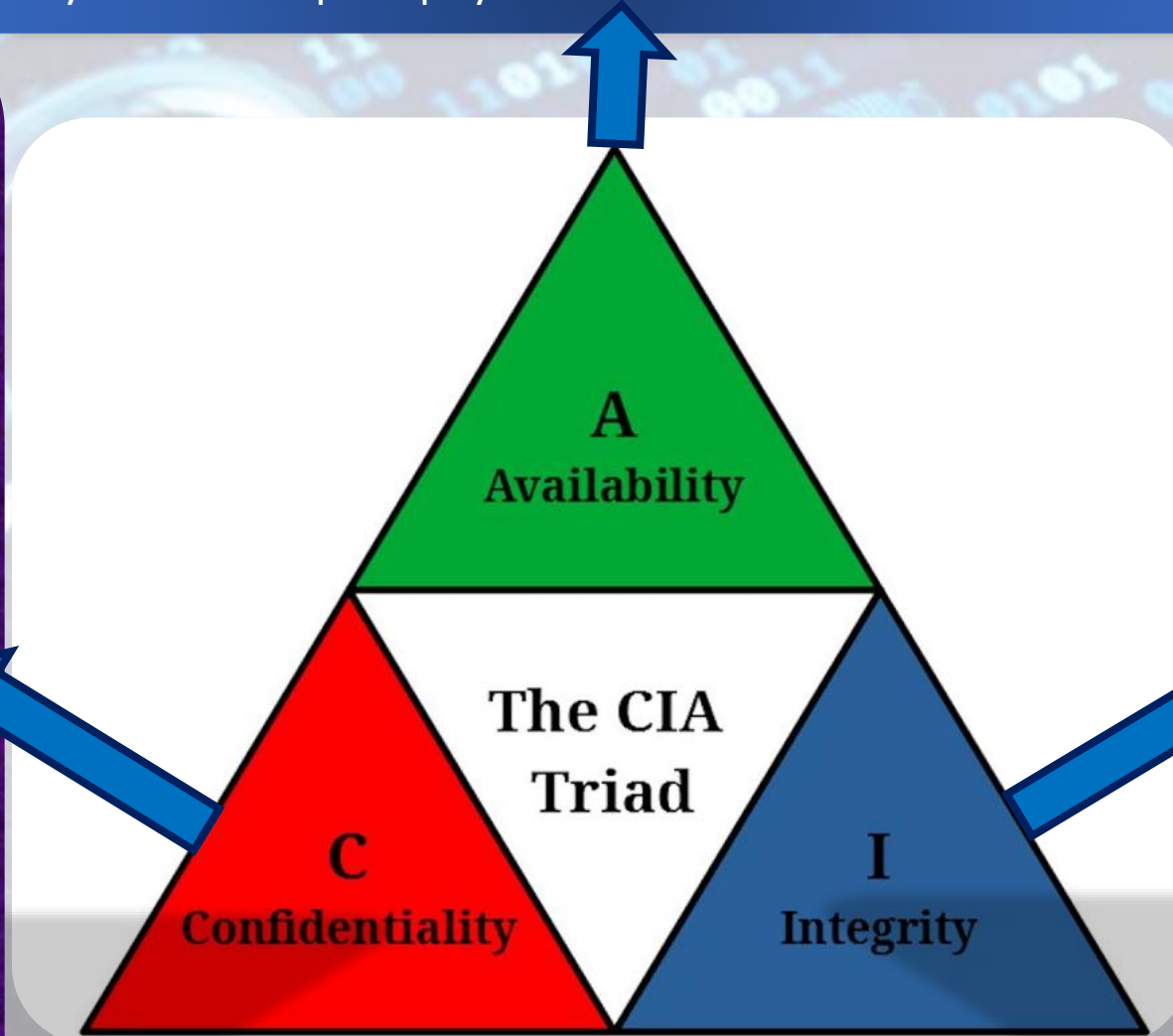
Assures that systems work promptly and service is not denied to authorized users.

This term covers two related concepts:

- Data confidentiality:

Assures that private or confidential information is not made available or disclosed to unauthorized individuals.

- Privacy: Assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed.



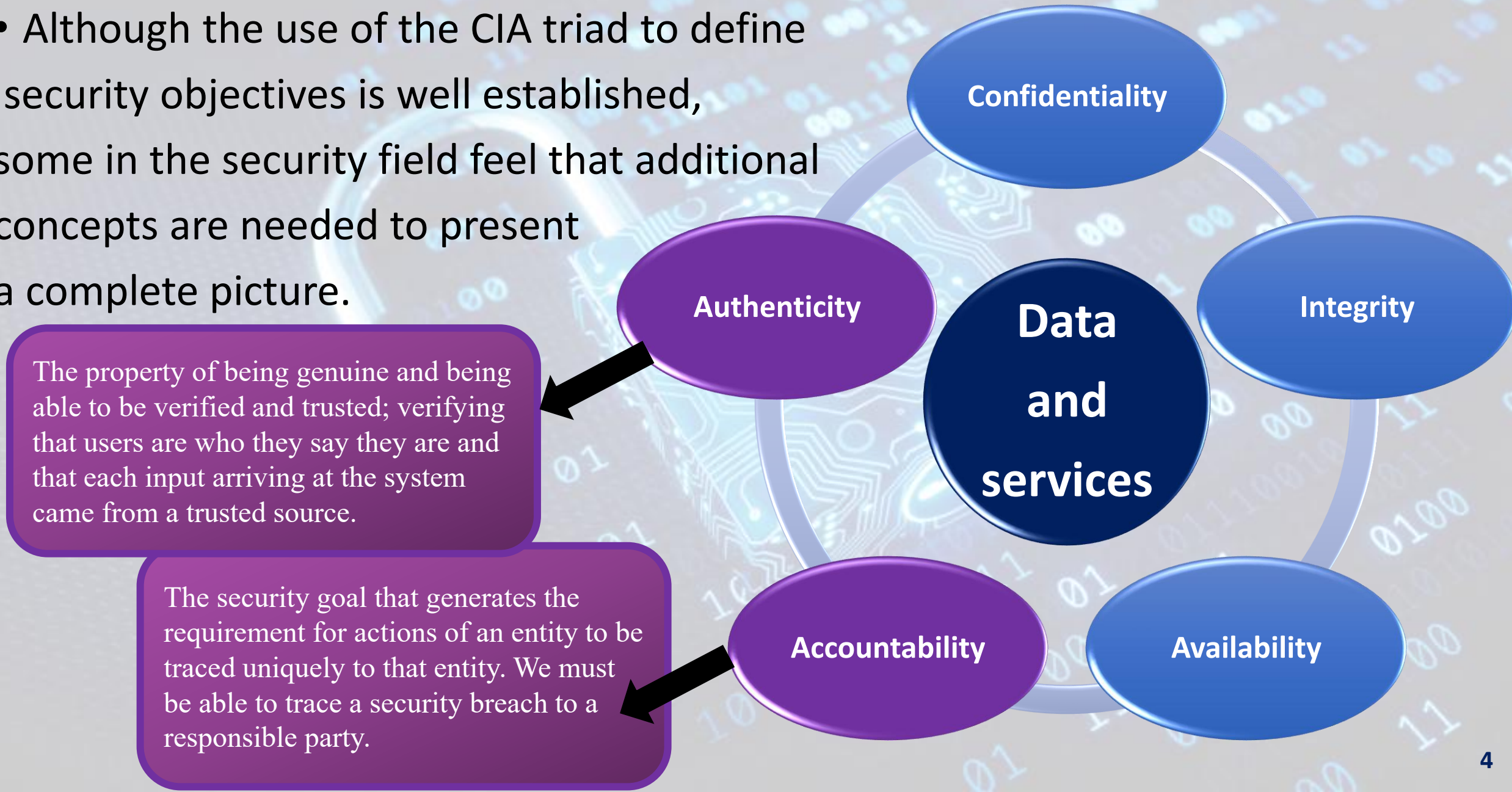
This term covers two related concepts:

- Data integrity: Assures that information (both stored and in transmitted packets) and programs are changed only in a specified and authorized manner.

- System integrity: Assures that a system performs its intended function in an undamaged manner, free from unauthorized manipulation of the system.

Computer Security Concepts

- Although the use of the CIA triad to define security objectives is well established, some in the security field feel that additional concepts are needed to present a complete picture.



Levels of Impact from a Security Breach

Low

Loss has **a limited** effect on organizational operations, organizational assets, or individuals.

- (i) cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced;
- (ii) result in minor damage to organizational assets;
- (iii) result in minor financial loss;
- (iv) result in minor harm to individuals.

Moderate

Loss has **a serious** effect on organizational operations, organizational assets, or individuals.

- (i) cause a significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is significantly reduced;
- (ii) result in significant damage to organizational assets;
- (iii) result in significant financial loss;
- (iv) result in significant harm to individuals that does not involve loss of life or serious, life-threatening injuries.

High

Loss has **a severe or catastrophic** effect on organizational operations, organizational assets, or individuals.

- (i) cause a severe degradation in or loss of mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions;
- (ii) result in major damage to organizational assets;
- (iii) result in major financial loss;
- (iv) result in severe or catastrophic harm to individuals involving loss of life or serious, life-threatening injuries.

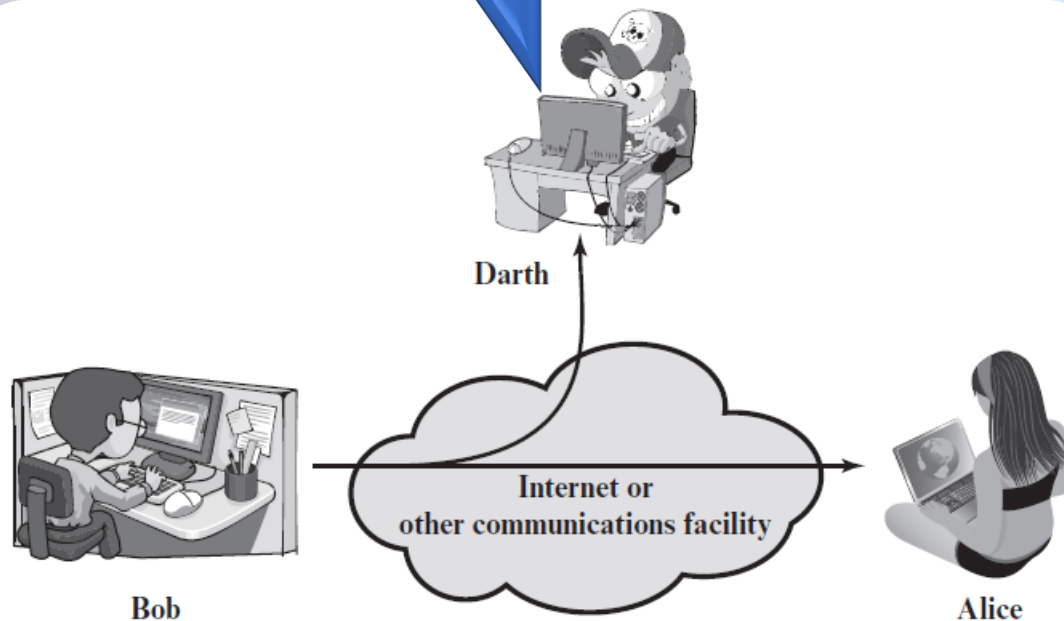
Examples

- Confidentiality:
 - High: students' grades
 - Moderate: students' enrollment information
 - Low: lists of students or faculty or departmental lists
- Integrity:
 - High: patient's information
 - Moderate: a Web site that offers a forum to registered users to discuss some specific topic.
 - Low: an anonymous online poll offered by Web sites, such as news organizations.
- Availability:
 - High: authentication services
 - Moderate: public Web site for a university
 - Low: an online telephone directory

Security Attacks

Passive:

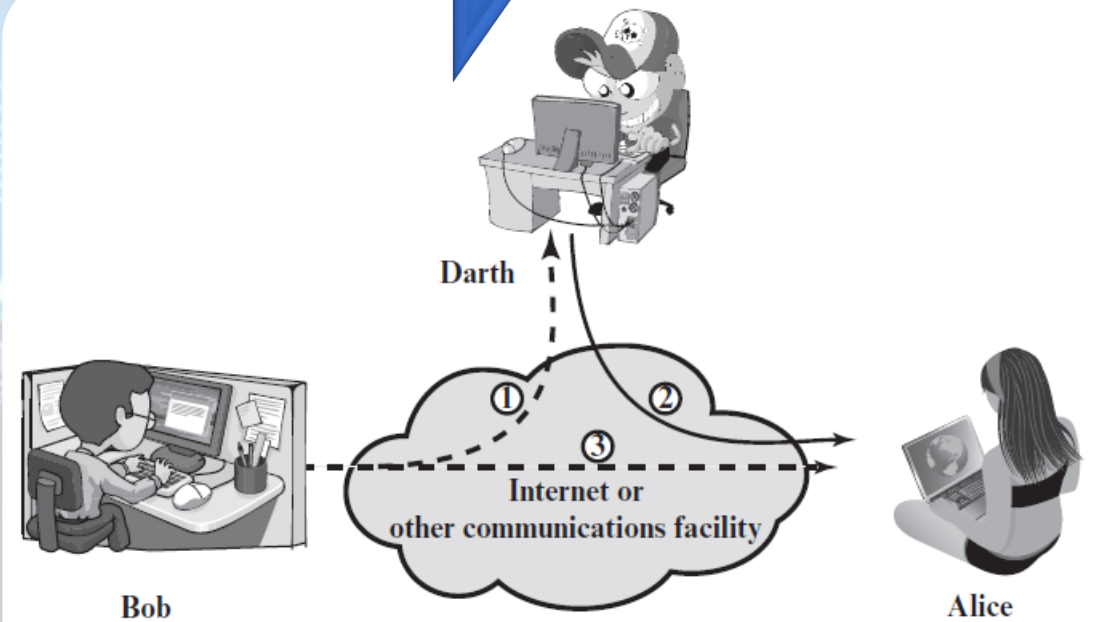
Attempts to learn or **make use** of information from the system but does not affect system resources.



(a) Passive attacks

Active:

Attempts to **alter** system resources or affect their operation



(b) Active attacks

Passive Attacks

- Passive attacks are concerned with **eavesdropping** on, or **monitoring** of, transmissions. The goal of the opponent is to obtain information that is being transmitted.
- Two types of passive attacks:
 - 1. Release of message contents:**
learning the contents of these transmissions
 - 2. Traffic analysis:**
monitor traffic flow to determine location and identity of communicating hosts and could observe the frequency and length of messages being exchanged
- Passive attacks are **very difficult to detect**, because they do not involve any alteration of the data. However, it is feasible to prevent the success of these attacks, usually by means of **encryption**. Thus, the emphasis in dealing with passive attacks is on **prevention** rather than detection.

Active Attacks

- Active attacks involve some **modification** of the data stream or the **creation** of a false stream.
- Active attacks can be subdivided into four categories:
 - 1. Masquerade**
one entity pretends to be a different entity
 - 2. Replay**
involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect
 - 3. Modification of messages**
means that some portion of a legitimate message is altered, or that messages are delayed or reordered, to produce an unauthorized effect
 - 4. Denial of service**
prevents or inhibits the normal use or management of communications facilities
- Active attacks present the opposite characteristics of passive attacks. It is quite **difficult to prevent** active attacks. The goal is to **detect** active attacks and to **recover** from them.

Security Services

Authentication: assurance that communicating entity is the one claimed.

Access Control: The prevention of unauthorized use of a resource (i.e., this service controls who can have access to a resource, under what conditions access can occur, and what those accessing the resource are allowed to do).

Data Confidentiality: protection of data from unauthorized disclosure.

Data Integrity: assurance that data received is as sent by an authorized entity.
(i.e., contain no modification, insertion, deletion, or replay).

Nonrepudiation: protection against denial by one of the parties in a communication.

A stylized padlock with a circuit board pattern, set against a background of binary code. The padlock is rendered in a light blue, translucent style with glowing yellow circuit traces. The background is a light blue gradient with a pattern of binary digits (0s and 1s) in a darker blue color.

For Self-Reading

Attack Surfaces and Attack Trees

- These are two concepts that are useful in **evaluating** and **classifying** threats.

Attack Surfaces:

- An attack surface consists of the reachable and exploitable vulnerabilities in a system.
- Examples:

- Open ports on outward facing Web and other servers, and code listening on those ports
- Services available on the inside of a firewall
- Code that processes incoming data, email, XML, office documents, and industry-specific custom data exchange formats
- Interfaces, SQL, and Web forms
- An employee with access to sensitive information vulnerable to a social engineering attack

Attack Surfaces

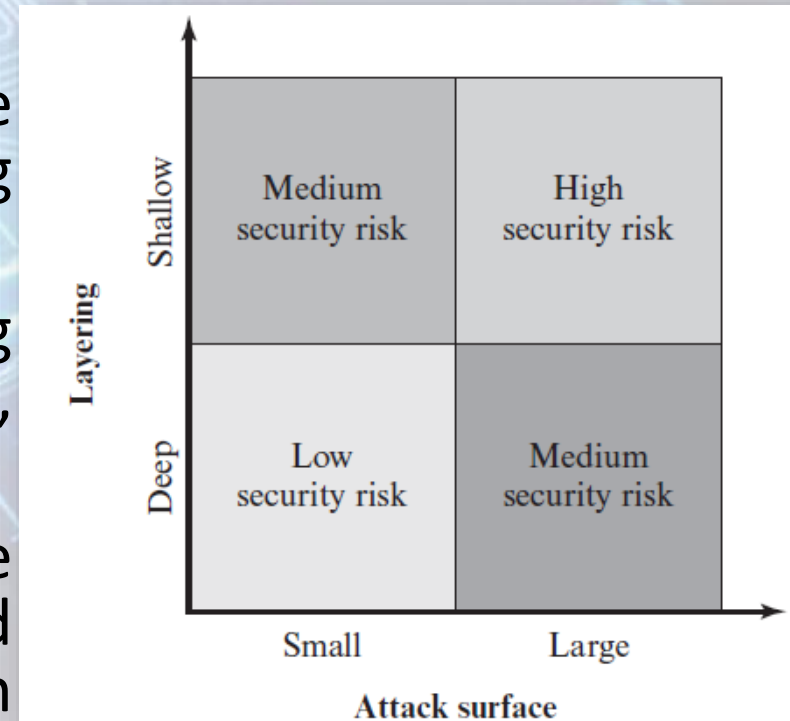
Attack surfaces can be categorized as follows:

- **Network attack surface:** This category refers to vulnerabilities over an enterprise network, wide-area network, or the Internet. Included in this category are network protocol vulnerabilities, such as those used for a denial of-service attack, disruption of communications links, and various forms of intruder attacks.
- **Software attack surface:** This refers to vulnerabilities in application, utility, or operating system code. A particular focus in this category is Web server software.
- **Human attack surface:** This category refers to vulnerabilities created by personnel or outsiders, such as social engineering, human error, and trusted insiders.

Attack Surfaces

Attack Surfaces:

- An attack surface analysis is a useful technique for assessing the **scale** and **severity** of threats to a system.
- A systematic analysis of points of vulnerability makes developers and security analysts aware of where security mechanisms are required.
- Once an attack surface is defined, designers may be able to find ways to make the surface smaller, thus making the task of the adversary more difficult.
- The attack surface also provides guidance on setting priorities for testing, strengthening security measures, and modifying the service or application.
- The use of **layering** referred to as **defense in depth** (the use of multiple, overlapping protection approaches), and attack surface reduction complement each other in mitigating security risk.



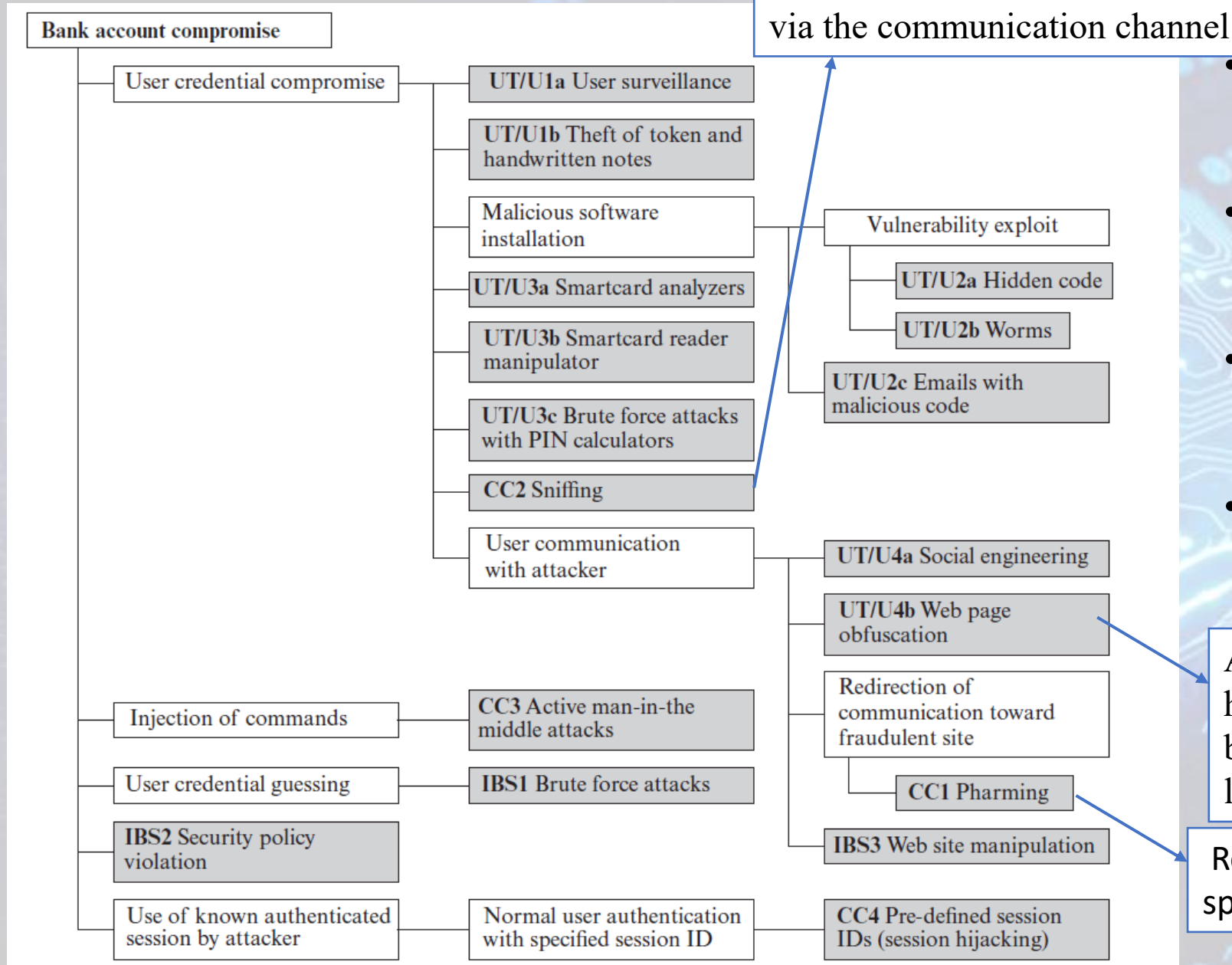
Attack Trees

- An attack tree is a **branching, hierarchical** data structure that represents a set of potential techniques for exploiting security vulnerabilities.
- The **security incident** that is the goal of the attack is represented as the **root** node of the tree, and the ways that an attacker could reach that goal are iteratively and incrementally represented as branches and subnodes of the tree.
- Each subnode defines a subgoal, and each subgoal may have its own set of further subgoals, and so on.
- The final nodes on the paths outward from the root, that is, the **leaf nodes**, represent different ways to **initiate an attack**.

Attack Trees

- Each node other than a leaf is either an **AND-node** or an **OR-node**.
 - To achieve the goal represented by an AND-node, the subgoals represented by all of that node's subnodes must be achieved;
 - For an OR-node, at least one of the subgoals must be achieved.
- Branches can be labeled with values representing difficulty, cost, or other attack attributes, so that alternative attacks can be compared.
- Security analysts can use the attack tree to document security attacks in a structured form that reveals key vulnerabilities.
- The attack tree can guide both the design of systems and applications, and the choice and strength of countermeasures.

Attack Trees



- Is an example of an attack tree analysis for an **Internet banking authentication application**.
- The root of the tree is the objective of the attacker, which is to compromise a user's account.
- The shaded boxes on the tree are the leaf nodes, which represent events that comprise the attacks.
- Note that in this tree, all the nodes other than leaf nodes are OR-nodes.

An obfuscated URL is a web address that has been obscured or concealed and has been made to imitate the original URL of a legitimate website.

Redirect internet users trying to reach a specific website to a different, fake site.

Attack Trees

- The analysis to generate this tree considered the three components involved in authentication:
 - **User terminal and user (UT/U):** These attacks target the user equipment, including the tokens that may be involved, such as smartcards or other password generators, as well as the actions of the user.
 - **Communications channel (CC):** This type of attack focuses on communication links.
 - **Internet banking server (IBS):** These types of attacks are offline attacks against the servers that host the Internet banking application.
- **Five overall attack strategies** can be identified, each of which exploits one or more of the three components. The five strategies are as follows:
 1. **User credential compromise**
 2. **Injection of commands**
 3. **User credential guessing**
 4. **Security policy violation**
 5. **Use of known authenticated session:** This type of attack persuades or forces the user to connect to the IBS with a preset session ID. Once the user authenticates to the server, the attacker may utilize the known session ID to send packets to the IBS.



Thank You